

# Primary sources & further reading

Part 13 —  AI Security · 13-ai-security/papers/PAPERS.md · 13-ai-security/resources/RESOURCES.md

## Papers & Primary Sources — AI Security

Run `bash ../_tools/fetch_papers.sh 13-ai-security` from the repo root to download the open-access PDFs into this folder. Items without a direct PDF link are noted.

### Read these two first

| # | Paper                                                                                                                                                                              | Why it matters                                                                                                                                                                                                                                                                                   | Link                                                            |
|---|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| 1 | <b>OWASP Top 10 for LLM Applications</b> — OWASP GenAI Security Project (living document, 2026 edition)                                                                            | The organizing frame for this entire module. Not a paper in the academic sense — a versioned, community-maintained risk taxonomy, now partly weighted by real incident data. Read the current edition, then skim the 2023 and 2025 changelogs to see how fast the field's consensus moves.       | <a href="https://owasp.org">genai.owasp.org</a>                 |
| 2 | <b>Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection</b> — Greshake, Abdelnabi, Mishra, Endres, Holz, Fritz (2023) | The paper that named and formalized indirect prompt injection as a class, with working demonstrations against real LLM-integrated apps (Bing Chat, code assistants). Read this before you read anything else about "agentic security" — it is the paper notes/01 section 3 is directly built on. | <a href="https://arxiv.org/abs/2302.12173">arXiv:2302.12173</a> |

### Attacks: injection and jailbreaking

| Paper                                                                                                                         | Year | One-line takeaway                                                                                                                                                                                                                                                                                    | Link                                                                                                              |
|-------------------------------------------------------------------------------------------------------------------------------|------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| Universal and Transferable Adversarial Attacks on Aligned Language Models — Zou, Wang, Carlini, Nasr, Kolter, Fredrikson      | 2023 | The GCG attack: gradient-optimized adversarial suffixes that reliably suppress refusals and transfer across models, including black-box, hosted ones. The paper that ended "instruction-tuning alone is robust" as a defensible claim.                                                               | <a href="https://arxiv.org/abs/2307.15043">arXiv:2307.15043</a>                                                   |
| Many-shot Jailbreaking — Anil, Durmus, Panickssery, Sharma, et al. (Anthropic)                                                | 2024 | Stuffing a long context with hundreds of faux compliant dialogues shifts in-context learning enough to break refusals at scale — an attack that exists <i>because</i> context windows got long, not despite it. Attack success climbs with shot count in a way that looks like a scaling law.        | <a href="https://anthropic.com/research/many-shot-jailbreaking">anthropic.com/research/many-shot-jailbreaking</a> |
| Great, Now Write an Article About That: The Crescendo Multi-Turn LLM Jailbreak Attack — Russinovich, Salem, Eldan (Microsoft) | 2024 | Formalizes the crescendo attack from notes/01 section 6: small, individually benign escalations across turns reach a place a single-turn ask would have been refused. 56% success on GPT-4, 83% on Gemini-Pro in their eval. Ships with PyRIT, Microsoft's open red-teaming toolkit (see resources). | <a href="https://arxiv.org/abs/2404.01833">arXiv:2404.01833</a>                                                   |

## Red-teaming methodology

| Paper                                                                                                                                       | Year | One-line takeaway                                                                                                                                                                                                                                                                            | Link                              |
|---------------------------------------------------------------------------------------------------------------------------------------------|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|
| Red Teaming Language Models with Language Models — Perez, Huang, Song, Cai, Ring, Aslanides, Glaese, McAleese, Irving (DeepMind)            | 2020 | Uses one LM to automatically generate test cases that elicit harmful behavior from a target LM — the founding paper for "automated red-teaming" as a category, one half of the mix notes/02 section 6 describes.                                                                             | <a href="#">arXiv :2202.03286</a> |
| Red Teaming Language Models to Reduce Harms: Methods, Scaling Behaviors, and Lessons Learned — Ganguli, Lovitt, Kernion, et al. (Anthropic) | 2022 | The human-red-teaming counterpart: 38,961 human-generated attacks released as a dataset, plus the finding that RLHF-tuned models get <i>harder</i> to red-team as they scale — a genuinely load-bearing, slightly uncomfortable result for anyone assuming bigger automatically means safer. | <a href="#">arXiv :2209.07858</a> |

## Data risks: extraction, poisoning, embeddings

| Paper                                                                                             | Year      | One-line takeaway                                                                                                                                                                                                                                                                                                                   | Link                              |
|---------------------------------------------------------------------------------------------------|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|
| Extracting Training Data from Large Language Models — Carlini, Tramer, Wallace, Jagielski, et al. | 2020/2021 | Recovers verbatim training examples (PII, UUIDs, code) from GPT-2 by querying it — the empirical proof behind notes/02 section 4's memorization-leakage discussion, and the reason "the model wasn't hacked" is not the same claim as "no disclosure occurred."                                                                     | <a href="#">arXiv :2012.07805</a> |
| Text Embeddings Reveal (Almost) As Much As Text — Morris, Kuleshov, Shmatikov, Rush               | 2023      | Vec2Text: iteratively decodes a dense embedding back into the original text, recovering 92% of 32-token inputs exactly, including full names from clinical notes. The direct evidence for notes/02 section 4's claim that a vector store needs the access-control discipline of the source documents, not "just numbers" treatment. | <a href="#">arXiv :2310.06816</a> |

## How to read a security paper (30 minutes, 3 passes)

1. **Pass 1 (5 min):** abstract, the attack's success-rate headline number, and which models it was tested against. Ask: is this a novel technique or a novel *combination* of known ones?
2. **Pass 2 (15 min):** the threat model section specifically — what does the attacker need (white-box gradient access? just an API key? one turn or many?). This is the single most important paragraph in any AI security paper and the one people skip fastest.
3. **Pass 3 (10 min):** the "defenses tried" or "limitations" section. Ask: does the proposed defense generalize, or does it just raise the bar for this exact published attack (see notes/01 section 4 on why that distinction matters)?

Keep a one-paragraph note per paper naming the threat model explicitly — six months from now, "works against GPT-4" without the threat model attached tells you nothing about whether it still applies.

## Resources — AI Security

### Frameworks and living references

| Resource                                              | What it's for                                                                                                                                                                   | Link                                                                                                                      |
|-------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| <b>OWASP GenAI Security Project — LLM Top 10</b>      | The taxonomy this module organizes around; check for a new edition roughly annually                                                                                             | <a href="https://genai.owasp.org/llm-top-10/">https://genai.owasp.org/llm-top-10/</a>                                     |
| <b>OWASP GenAI Security Project — home</b>            | Also publishes the Agentic AI Security guidance, an AI security checklist, and a MAESTRO threat-modeling framework for multi-agent systems                                      | <a href="https://genai.owasp.org/">https://genai.owasp.org/</a>                                                           |
| <b>MITRE ATLAS</b>                                    | ATT&CK-style knowledge base of adversary tactics/techniques against AI systems, with real case studies — use it to threat-model a system the way you'd use ATT&CK for a network | <a href="https://atlas.mitre.org/">https://atlas.mitre.org/</a>                                                           |
| <b>NIST AI Risk Management Framework (AI RMF 1.0)</b> | The US government's map/measure/manage/govern framework; pairs with Module 12/14's governance and compliance framing                                                            | <a href="https://www.nist.gov/itl/ai-risk-management-framework">https://www.nist.gov/itl/ai-risk-management-framework</a> |

### Tools worth running yourself

| Tool                                     | What it does                                                                                                                                                                            | Link                                                                                            |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <b>garak</b> (NVIDIA)                    | An "nmap for LLMs" — a CLI vulnerability scanner that runs a library of probes (jailbreaks, injections, data leakage, toxicity) against a target model and reports which ones land      | <a href="https://github.com/NVIDIA/garak">https://github.com/NVIDIA/garak</a>                   |
| <b>promptfoo</b> (red-team mode)         | Declarative-config LLM eval and red-teaming tool: define a target, pick attack plugins (injection, jailbreak, PII, excessive agency, and more), get a scored report — usable in CI      | <a href="https://www.promptfoo.dev/docs/red-team/">https://www.promptfoo.dev/docs/red-team/</a> |
| <b>PyRIT</b> (Microsoft)                 | Python framework for orchestrating red-team attacks against generative AI systems at scale, including a working implementation of the Crescendo multi-turn attack from papers/PAPERS.md | <a href="https://github.com/microsoft/PyRIT">https://github.com/microsoft/PyRIT</a>             |
| <b>Anthropic's red-teaming resources</b> | Anthropic's public research and practices around red-teaming, jailbreak robustness, and Constitutional Classifiers (their defense against universal jailbreaks)                         | <a href="https://www.anthropic.com/research">https://www.anthropic.com/research</a>             |
| <b>vec2text</b>                          | The reference implementation behind the embedding-inversion paper in papers/PAPERS.md — run it yourself to see how much text a "just numbers" embedding actually reveals                | <a href="https://github.com/vec2text/vec2text">https://github.com/vec2text/vec2text</a>         |

## Courses and structured learning (free)

| Course                                                         | Who it's for                                                                                                                               | Link                                                                                                                            |
|----------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| <b>OWASP GenAI Security Project — LLM Top 10 guidance docs</b> | The most direct, free, no-signup path into this module's core frame, per-category                                                          | <a href="https://genai.owasp.org/llm-top-10/">https://genai.owasp.org/llm-top-10/</a>                                           |
| <b>Learn Prompting — Prompt Hacking course</b>                 | Free, hands-on introduction to injection and jailbreak techniques from the offensive side, useful for building intuition before you defend | <a href="https://learnprompting.org/docs/category/-prompt-hacking">https://learnprompting.org/docs/category/-prompt-hacking</a> |
| <b>Microsoft — AI red teaming learning path (Learn)</b>        | Structured, free modules on red-teaming generative AI systems using PyRIT                                                                  | <a href="https://learn.microsoft.com/en-us/security/ai-red-team/">https://learn.microsoft.com/en-us/security/ai-red-team/</a>   |
| <b>Stanford CS 329T / related AI security seminars</b>         | Academic depth on adversarial ML if you want the underlying math, not just the applied practice                                            | <a href="https://cs329t.stanford.edu/">https://cs329t.stanford.edu/</a>                                                         |

## Repositories worth cloning

| Repo                                                                                                | What's inside                                                                                                     |
|-----------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <a href="https://github.com/NVIDIA/garak">https://github.com/NVIDIA/garak</a>                       | The scanner itself, plus its probe/detector library — read the probes directory to see the current attack catalog |
| <a href="https://github.com/promptfoo/promptfoo">https://github.com/promptfoo/promptfoo</a>         | The eval/red-team engine; <code>site/docs/red-team/</code> is a genuinely good written curriculum on its own      |
| <a href="https://github.com/microsoft/PyRIT">https://github.com/microsoft/PyRIT</a>                 | Orchestrators, targets, and scorers for automated multi-turn red-teaming                                          |
| <a href="https://github.com/llm-attacks/llm-attacks">https://github.com/llm-attacks/llm-attacks</a> | Official code for the GCG adversarial-suffix attack (papers/PAPERS.md) — read, don't deploy                       |
| <a href="https://github.com/vec2text/vec2text">https://github.com/vec2text/vec2text</a>             | Embedding inversion reference implementation                                                                      |
| <a href="https://github.com/microsoft/PromptBench">https://github.com/microsoft/PromptBench</a>     | Adversarial prompt robustness benchmarking                                                                        |

Clone the starter set with: `bash ../_tools/clone_repos.sh 13-ai-security`

## Communities

- OWASP GenAI Security Project Slack/ mailing list — linked from <https://genai.owasp.org/>
- `r/artificial` and `r/MachineLearning` (safety- and red-teaming-tagged threads) — <https://www.reddit.com/r/MachineLearning/>
- AI Village (DEF CON) — the AI/ML security community that runs the annual DEF CON AI red-teaming events — <https://aivillage.org/>
- Papers with Code, "adversarial attack" and "red teaming" task pages — <https://paperswithcode.com/>

## Cheat sheets

- OWASP LLM Top 10 quick-reference card (linked from the project page) — <https://genai.owasp.org/llm-top-10/>
- MITRE ATLAS technique matrix (the visual overview, same idea as the ATT&CK matrix) — <https://atlas.mitre.org/matrices/ATLAS>
- Also see ../../\_shared/cheatsheets/